

Organizando a Segurança da Informação

Objetivo da Aula

Conhecer os principais elementos utilizados na infraestrutura de segurança da informação. Veremos que cada elemento atende a uma necessidade específica da organização, considerando fatores como recursos financeiros e de pessoal disponível.

Apresentação

A segurança da informação é um pilar fundamental para o funcionamento seguro e eficaz de qualquer organização, independentemente do seu tamanho ou setor de atuação. Nesta aula, vamos explorar a importância de estabelecer uma base sólida para a gestão da segurança da informação em uma organização. A organização adequada da segurança da informação envolve a definição de políticas, estruturas e práticas que garantem a proteção dos ativos de informação da empresa e a redução de riscos.

Nossas discussões se concentrarão em como criar uma estrutura organizacional para lidar com a segurança da informação, a importância de políticas de segurança bem definidas, a classificação e rotulagem adequada de informações, a gestão de acesso e controle de privacidade, bem como a implementação de programas de treinamento e conscientização em segurança. Estes elementos desempenham um papel crucial na proteção dos dados sensíveis e na promoção de uma cultura de segurança sólida dentro da organização.

1. Construindo a Fortaleza da Defesa Digital

Para gerenciar a segurança da informação em uma organização, é necessário coordenar e supervisionar todas as atividades, políticas, processos e práticas relacionadas à segurança da informação em uma empresa ou entidade. Isso envolve a implementação de medidas e estratégias para proteger os ativos de informação da organização contra ameaças, vulnerabilidades e riscos que possam comprometer a confidencialidade, integridade e disponibilidade destes ativos.

Como garantia de que a segurança de informação seja tratada como uma prioridade estratégica, não como uma preocupação isolada, utilizamos uma abordagem unificada na criação da infraestrutura de segurança da informação. Esta abordagem é um modelo de gestão onde a direção e o chefe de segurança trabalham em conjunto, coordenadamente, para garantir a eficácia das medidas de segurança da informação. Visando integrar a segurança em todos os aspectos das operações da organização, esta abordagem força um compromisso organizacional e promove uma cultura de segurança que pode, e deve, ser monitorada e melhorada continuamente.

Devido à natureza de defesa, ataque e ameaças relacionadas à segurança da informação, é possível imaginar que a Segurança da Informação seja uma fortaleza digital, construída pela equipe para proteger os tesouros da organização, sendo que os tesouros são as informações e ativos. A defesa em si, então, é como uma missão de operações especiais em um ambiente digital repleto de ameaças e desafios constantes. Para lidar com esses desafios, é essencial criar uma estrutura de comando sólida, semelhante a uma hierarquia militar, que coordene e supervise todas as atividades relacionadas à segurança da informação. Vamos aprofundar a importância dessa estrutura de comando e como ela funciona, começando na mais alta patente, com o “general”.

1.1. Chief Information Security Officer

O *Chief Information Security Officer* (Oficial Chefe de Segurança da Informação, em tradução livre), ou CISO, é o equivalente ao general na hierarquia militar deste nosso exercício de imaginação. Este líder é responsável por definir a visão estratégica da segurança da informação na organização e liderar a implementação de medidas de segurança eficazes.

Como general, ou comandante-chefe, desta fortaleza digital, o CISO tem a missão principal de garantir que a organização esteja preparada para enfrentar ameaças digitais, proteger dados sensíveis e manter a integridade dos sistemas. Cabe ao CISO:

- **Gestão de riscos:**
 - Identificar e avaliar riscos à segurança da informação e desenvolver estratégias para mitigá-los.
- **Desenvolver políticas de segurança:**
 - Criar políticas de segurança que estabeleçam diretrizes para proteger os ativos de informação da organização;
 - Também chamados de PSI (Política de Segurança da Informação) ou POSIC (Política de Segurança da Informação e Comunicações).

- **Implementar controles de segurança:**
 - Adotar medidas de segurança, como firewalls, criptografia e sistemas de detecção de intrusões.
- **Treinamento e conscientização:**
 - Educar os demais funcionários sobre as boas práticas de segurança de informação e a importância de proteger os dados.
- **Gestão de equipe:**
 - Liderar e coordenar equipes de especialistas em segurança.
- **Respostas a incidentes:**
 - Coordenar a resposta a incidentes de segurança, incluindo a investigação e a mitigação de danos.
- **Relatórios para a alta administração:**
 - Comunicar informações de segurança à alta administração e ao conselho de diretores.
- **Conformidade legal:**
 - Garantir que a organização esteja em conformidade com os regulamentos de segurança da informação.
- **Desenvolver estratégias de segurança:**
 - Criar planos estratégicos de segurança da informação alinhados com os objetivos da organização.

Repare como estas funções funcionam bem com a nossa alusão militar ao comandante-chefe/general. O CISO é o chefe da segurança digital da organização, liderando o esforço para proteger os ativos de informação e garantir que a organização esteja preparada para enfrentar ameaças cibernéticas.

Um dos principais papéis dentre esses é a produção do PSI (Política de Segurança da Informação). Em um processo colaborativo com outros departamentos e partes interessadas (para haver um levantamento correto de necessidades e riscos), o CISO lidera a equipe na criação de uma política abrangente, que aborda as necessidades específicas da organização.

Após o desenvolvimento inicial, a PSI deve passar por uma revisão interna, na qual as partes interessadas, incluindo os departamentos de TI, jurídico e operações, examinam o documento para garantir que eles estejam de acordo com as necessidades das organizações em questão. Nesta etapa, é necessário checar também os conformes legais.

Caso a revisão interna seja validada, o PSI é submetido à direção, que avalia a política para garantir que ela esteja alinhada com os objetivos estratégicos da organização e que forneça um nível adequado de proteção da informação. Ao ser aprovada, se faz necessário a implementação e o treinamento. Os funcionários devem ser treinados nas diretrizes e práticas da política aprovada.

1.2. Direção

O CISO ainda deve responder à direção da organização. A direção não é apenas um órgão regulatório, que cumpre obrigações de conformidade; ela deve ser uma força motriz por trás da segurança da informação. Isto significa que a alta administração não vê a segurança da informação como uma tarefa isolada, mas como um elemento estratégico, que afeta diretamente o sucesso e a reputação da organização.

É de responsabilidade da diretoria atribuir funções de segurança a indivíduos ou equipes específicas dentro da organização. Isso garante que a responsabilidade pela segurança da informação seja distribuída eficazmente. Cada membro da equipe compreende claramente suas funções e responsabilidades na proteção dos ativos digitais.

Como dito no item anterior, é necessário envolvimento da direção para a aprovação do PSI. Este envolvimento mostra um comprometimento na promoção de uma cultura de segurança da informação dentro da organização. Após a implementação do PSI, a diretoria deve também fazer o papel de coordenação e supervisão. Este papel ativo garante a correta implementação e utilização das políticas e, então, permite que haja um monitoramento do progresso das estratégias de proteção, além da avaliação de sua eficácia.

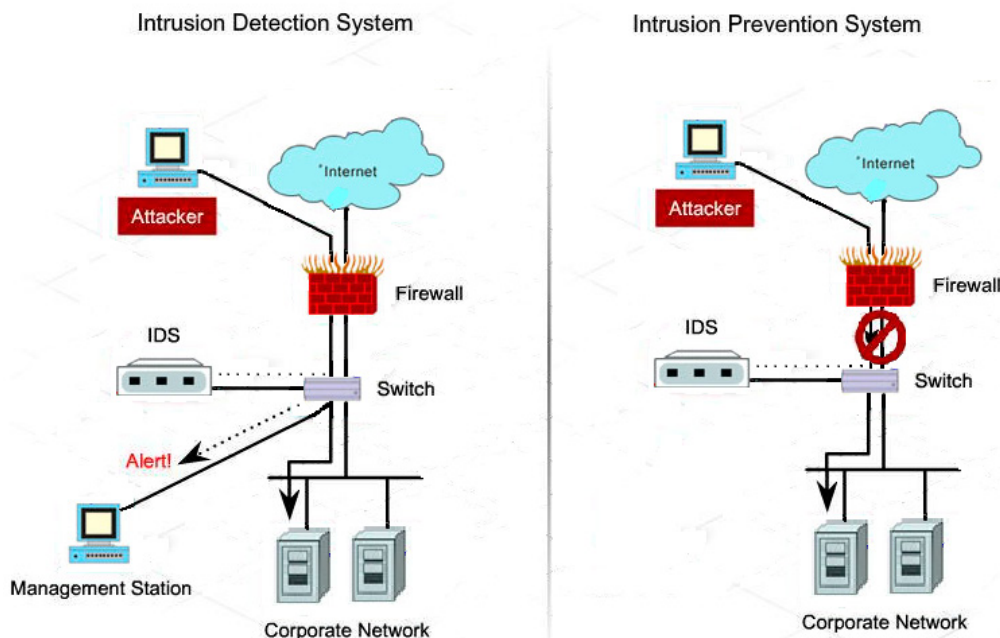
Em resumo, a direção desempenha um papel vital na segurança da informação, indo além de simplesmente aprovar políticas e regulamentações. Liderando, por exemplo, a direção garante que a segurança seja uma prioridade estratégica alinhada com os objetivos da organização, permeando todos os seus processos e operações, promovendo confiança entre seus funcionários, *stakeholders*, e até mesmo na relação pública da empresa.

2. Infraestrutura de Segurança

Uma empresa ou organização que busca ser competitiva no mercado necessita investir em segurança da informação. Sem este investimento, sempre aumenta o risco e a possibilidade de ataques e invasões, que podem ser fatais para a organização. A segurança da informação se tornou essencial em praticamente todas as áreas do mercado. Este investimento em

segurança é feito, principalmente, em duas áreas: profissionais qualificados e infraestrutura, que garantem os princípios básicos de segurança de informação.

Figura 1: Sistemas de Detecção e Prevenção de Intrusões



Fonte: UFRJ. Disponível em: https://www.gta.ufrj.br/grad/16_2/2016IDS/conceituacao.html. Acesso em: 26 jan. 2024.

Os profissionais podem ser contratados como funcionários diretos da empresa, ou uma empresa prestadora de serviço pode ser contratada para construir e gerenciar a segurança da organização em questão. Diversos aspectos de tecnologia são desconhecidos pela gestão, por isso, se faz necessário o funcionário qualificado nesta área, para montar corretamente a infraestrutura de segurança.

Com uma infraestrutura bem montada, o trabalho contínuo de monitoramento e melhoria dos funcionários de segurança da informação se torna muito mais fácil e rápido. Vamos ver abaixo alguns itens essenciais da infraestrutura de segurança e suas funções:

- **Firewall:**

- Dispositivos de segurança que controlam o tráfego de rede, permitindo ou bloqueando o acesso a sistemas com base em regras predefinidas. Eles atuam como uma barreira entre a rede interna e a externa, filtrando tráfego malicioso. Em muitas empresas, este dispositivo é utilizado na rede interna também para separar e resguardar o acesso a sistemas críticos. Hoje, as empresas utilizam o firewall de rede e firewall de aplicação;

- O firewall de aplicação é uma solução entre os servidores de aplicação da empresa e o mundo externo. O firewall de aplicação é especializado na camada 7 do TCP/IP e filtra todo tráfego que passa por ele. Dessa forma, ele verifica, por exemplo, se vulnerabilidades conhecidas do IIS (*Internet Information Services*) ou *Apache* estão sendo utilizadas e bloqueia o fluxo antes que chegue nos servidores de aplicação, criando mais uma camada de segurança.

- **Antivírus:**

- Apesar de não serem garantia de um sistema sem ataques e invasões, um bom antivírus consegue eliminar a grande maioria das ameaças que um computador encontra no seu dia a dia;
- Vírus, trojans e outros tipos de malware evoluem constantemente. Para detectá-los e responder rapidamente, os antivírus devem estar sempre atualizados com a versão mais recente, que pode identificar ameaças e orientar o usuário sobre as ações apropriadas com base na ameaça detectada.

- **Sistemas de Detecção e Prevenção de Intrusões:**

- Também chamados de IDS e IPS (*Intrusion Detection System* e *Intrusion Prevention System*);
- Ambos os sistemas monitoram a rede em busca de atividades suspeitas ou padrões de tráfego maliciosos;
- IDS identifica ameaças em tempo real e manda um alerta para a gerência de segurança;
- IPS identifica ameaças em tempo real e bloqueia automaticamente atividades maliciosas:
 - É necessário cautela ao implementar, pois pode acabar bloqueando atividades bem-intencionadas se mal configurado.

- **Controle de acessos:**

- O controle de acessos implementa políticas e mecanismos que garantem que apenas pessoas autorizadas tenham acesso a sistemas e dados. Isso inclui autenticação de usuário, autorização com base em função e sistemas de gerenciamento de identidade:
 - Sistemas como o *Active Directory*, da Microsoft, permite gerenciar e controlar o acesso de usuários e dispositivos em redes corporativas.

- Cabe dentro do controle de acesso à função de **Logging**:
 - **Logging** é um monitoramento contínuo que registra as atividades do sistema e da rede;
 - **Logs**, que são como diários, bem detalhados, auxiliam a rastrear eventos e identificar comportamentos suspeitos.
- **Backups:**
 - Uma política de **backup** permite que os dados estejam disponíveis mesmo em casos em que uma ameaça seja bem-sucedida;
 - Redundância é a maior proteção de disponibilidade;
 - Nuvem:
 - Método comum e considerado bastante seguro para armazenar dados e **backups**;
 - Armazena os seus dados em uma máquina em um local remoto que lhe confere acesso via internet;
 - Sua segurança real é definida pela segurança de onde este banco de dados está localizado. Sejam empresas terceiras ou ela mesma.
- **Updates e Atualizações:**
 - Atualizações de firmware e software reduzem e mitigam a vulnerabilidade, ajudando a garantir um ambiente mais seguro da infraestrutura. Sempre utilize sistemas e infraestruturas atualizadas.
- **Controle de e-mail e mensagens internas:**
 - Controlar SPAM é a maneira mais efetiva de combater o **Phishing**;
 - O controle dos e-mails e mensagens permite rastrear ameaças que podem ser passadas por estes meios.
- **Padronização:**
 - Padronizar o sistema operacional da empresa simplifica a gestão, melhora a automação, aumenta a produtividade e fortalece a segurança de TI, pois reduz a complexidade, assim mitigando riscos e ameaças;
 - Padronizar softwares e configurações reduz ainda mais a complexidade, tornando o trabalho dos responsáveis pela segurança ainda mais fácil;
 - Utilização de uma imagem:

- Chamamos de imagem uma representação completa e estática de um sistema operacional ou de uma configuração específica de software, incluindo todos os arquivos, configurações e drivers necessários para a instalação em uma máquina;
- Utilizando imagens, podemos garantir que todas as máquinas sejam idênticas após a instalação, facilitando sua proteção e diagnóstico de problemas.

- **Inventário:**

- Manter um inventário completo de ativos de TI, incluindo hardware e software, fornece um controle preciso sobre os recursos necessários para o desempenho eficaz dos negócios, facilitando o gerenciamento e a manutenção.



Você Sabia?

O termo “firewall”, que originalmente se referia a paredes a prova de fogo que protegem contra incêndios, começou a ser usado na década de 80 para descrever a função de filtros em roteadores que separavam e protegiam ambientes ou dispositivos. A popularização do termo é atribuída ao filme *Wargames – Jogos de Guerra*, um filme de ficção científica sobre hackers, estrelado por Matthew Broderick em sua estreia.



Para Refletir

Assista ao filme *Guerreiros da Internet*. O roteiro didático e apresenta o funcionamento dos principais dispositivos de uma rede de computadores. Confira, legendado em português, aqui:

Disponível em: https://www.youtube.com/watch?v=hoZov_-rh3U. Acesso em: 26 jan. 2024.

Essa lista mostra os itens mais comuns de se encontrar em uma infraestrutura de segurança de redes, porém não são as únicas possibilidades e nem são todas obrigatórias em nenhuma infraestrutura. É claro que alguns são mais essenciais e, portanto, devem ser implementados numa parcela maior de organizações, como firewall, antivírus, manter os sistemas atualizados e manter tanto um inventário quanto um **backup**. Porém, a equipe responsável por construir a infraestrutura de segurança deve levar sempre em consideração as condições, objetivos e necessidades da organização para a qual eles estão trabalhando.

Um negócio pequeno, com poucos funcionários e computadores, talvez não precise de padronização com imagem ou de sistemas complexos de **backup**, mas certamente vai precisar de antivírus, firewall e controle de acesso. Já uma empresa grande o suficiente, pode sentir a necessidade de ter todas essas medidas e mais algumas, que não estão listadas, com mais esquemas de redundância, criptografias pesadas, VPNs e por aí vai.

Dentro destes itens, há variações consideráveis. Uma empresa grande pode decidir montar um CPD ou um banco de dados remoto, com redundância, **backups** amplos e acessíveis, ou até mesmo **backups** fora da rede para evitar problemas. Mas uma empresa pequena pode preferir contratar um sistema de **backup** na nuvem, terceirizando este serviço a uma empresa qualificada e preparada para receber as suas demandas.

Os principais fatores a se considerar ao decidir que elementos de infraestrutura de segurança devem ser implementados em uma organização são: ameaças específicas, quais são os ativos críticos, requisitos legais e regulatórios, orçamento e recursos disponíveis, integração com processos de negócios, custos de manutenção, monitoramento e auditoria.

Considerações Finais da Aula

A metáfora da fortaleza digital ressalta a natureza crítica de segurança da informação e a constante batalha contra ameaças e desafios digitais, a criação de uma estrutura de comando sólida, liderada pelo CISO, reflete a importância de uma abordagem coordenada e estratégica para a segurança cibernética. No entanto, a segurança da informação não é uma tarefa isolada; requer o envolvimento ativo da alta administração e uma cultura de segurança que permeia todas as operações.

A direção desempenha um papel vital ao atribuir responsabilidade, aprovar políticas, coordenar a implementação e supervisionar a eficácia das medidas de segurança. Além disso, exploramos os componentes essenciais da infraestrutura de segurança, desde firewalls, que atuam como sentinelas digitais, até antivírus, que combatem ameaças em evolução constante.

É fundamental lembrar que não existe uma solução única para todos os casos. A escolha dos elementos de infraestrutura de segurança deve ser baseada nas necessidades específicas da organização, considerando fatores como ameaças, ativos críticos, requisitos legais, recursos financeiros e de pessoal disponível.

Em resumo, construir a fortaleza da defesa digital requer planejamento estratégico, liderança comprometida e a implementação de uma infraestrutura de segurança adaptável.

Compreender a importância de proteger os ativos de informação e as melhores práticas para alcançar esse objetivo é fundamental para qualquer organização que deseje navegar com sucesso no mundo digital de hoje, garantindo a integridade, confidencialidade e disponibilidade de seus recursos mais valiosos.

Material Complementar



Vídeo

Guerreiros da Internet

2011, Moisés Robles.

Excelente filme (versão dublada em português), apresentando o funcionamento da rede de computadores e seus principais dispositivos.

Disponível em: https://www.youtube.com/watch?v=hoZov_-rh3U. Acesso em: 26 jan. 2024.

Referências

CARTILHA de Segurança para Internet. **CERT.br**, 2024. Disponível em: <https://cartilha.cert.br/>. Acesso em: 1º ago. 2023.

CARTILHA de Segurança para Internet para crianças. **CERT.br**, 2024. Disponível em: <https://internetsegura.br/criancas/>. Acesso em: 1º ago. 2023.